EMAIL FORENSICS LAB

KINGFORD PHISH INVESTIGATION

Lookalike-domain phishing • Email header analysis

PRACTICAL WALKTHROUGH | INVESTIGATOR-LED CTF

This exercise places participants in the role of an email-forensics investigator responding to a suspected lookalike-domain phishing message. They must inspect the message and its transport headers to establish the recipient domain, sender domain, source IP recorded in the mail-delivery path, and country associated with that IP.

Primary evidence: The suspicious email and its complete raw headers. The Kingford Phish CTF page provides four answer-validation challenges; it is not a substitute for the original email evidence.

1. LEARNING OBJECTIVE

The objective is to teach a structured method for investigating suspected phishing emails through header analysis. Participants will extract sender and recipient domain information, interpret the `Received` header chain, identify a candidate source IP, and enrich that IP with geolocation information.

By completing the exercise, participants should be able to:

- Access and inspect the complete raw source of an email in Thunderbird or an equivalent client.
- Differentiate the visible sender identity from the domain used to send the message.
- Identify the recipient's email domain from the addressing information.
- Read Received headers and identify a relevant connecting IP address.
- Use an approved IP-intelligence service to determine the country associated with an IP.
- Corroborate findings and document uncertainty rather than treating individual headers as conclusive proof.

2. BENEFICIARIES

This practical is suitable for SOC analysts, email-security administrators, incident responders, digital-forensics investigators, threat-intelligence analysts, and cybersecurity trainees. It is useful for learners developing hands-on skills in phishing triage and email metadata analysis.

3. INVESTIGATION NARRATIVE

An organisation has received a suspicious email that may be part of a lookalike-domain phishing campaign. The message has been escalated because its sender identity or sending infrastructure appears unusual. You are assigned as the investigator. Inspect the original email, review its complete headers, and establish the recipient domain, sender domain, IP address recorded in the trusted mail-transfer path, and country associated with that IP. Submit evidence-backed answers through the Kingford Phish CTF challenge page.

Investigation boundary: The CTF defines four flags—recipient domain, attacker domain, source IP, and IP geolocation country. The HTML challenge page does not expose the original email headers or readable answer values. Obtain those from the email evidence and corroborating lookups.

4. REQUIRED MATERIALS

- Suspicious email message with full/raw headers available.
- Thunderbird or another email client that can display original message source.
- Text editor for reviewing and recording header fields.
- Approved IP geolocation or threat-intelligence lookup service.
- Access to the Kingford Phish CTF submission page.

5. INVESTIGATION WORKFLOW

1. Preserve the email evidence

Retain the original message. If exporting it, preserve the complete headers and body. Record the evidence filename, acquisition context, and a cryptographic hash where practical. Forwarding can alter or omit header information.

2. Open the raw message source

In Thunderbird, open the message and use the message-source view (commonly Ctrl+U, or the relevant menu option). Locate From, To, Return-Path, Message-ID, and Received fields. Preserve the complete header block.

3. Determine the recipient domain

Inspect the To field and identify the domain portion after the @ symbol. Record the domain without the recipient's local-part. If multiple recipients are present, follow the challenge's intended evidence and document which address was used.

4. Determine the sender domain

Inspect sender-related fields, including From and Return-Path, and compare them with authentication results and other header evidence when available. Do not assume the visible display name proves sender identity.

5. Trace the Received headers

Read Received fields from the bottom upward to reconstruct the route. Prioritise entries added by known, trusted mail servers. Identify the relevant connecting IP and record the exact header line supporting it.

6. Enrich the IP address

Query the candidate public IP using an approved geolocation or threat-intelligence source. Record the country, lookup provider, and lookup time. Geolocation may identify a hosting provider, VPN, relay, or mail gateway—not an individual's physical location.

7. Submit and document the flags

Enter the four findings in the CTF page: recipient domain, attacker domain, source IP address, and country. Record the evidence location and reasoning for each answer.

Forensic caution: Email headers can contain forged or misleading values. A sender can add arbitrary header text before transmission, while receiving mail servers append their own Received lines. Trust boundaries matter. Use Received entries added by known, trusted infrastructure and corroborate them with mail-gateway logs or authentication results where available. IP geolocation does not establish the identity or physical location of a person.

6. INVESTIGATION QUESTIONS

Use the original email and its complete headers to answer these reworded questions. Each challenge item is worth 10 points, for a maximum score of 40 points.

Q1. What domain is associated with the intended recipient's email address?

Evidence to retain: the relevant email address/header line, IP lookup result, and lookup timestamp as applicable.

Q2. Which domain appears in the sender address used to deliver the suspicious message?

Evidence to retain: the relevant email address/header line, IP lookup result, and lookup timestamp as applicable.

Q3. According to the relevant Received header, what IP address connected to the receiving mail infrastructure?

Evidence to retain: the relevant email address/header line, IP lookup result, and lookup timestamp as applicable.

Q4. Which country is associated with the identified source IP according to an IP geolocation lookup?

Evidence to retain: the relevant email address/header line, IP lookup result, and lookup timestamp as applicable.

7. EVIDENCE RECORDING CHECKLIST

- Original email preserved; full raw headers available.
- Recipient address and extracted recipient domain recorded.
- From and Return-Path values compared; sender domain documented.
- Received header chain reviewed from bottom to top.
- Candidate source IP tied to a specific trusted Received line.
- IP geolocation result recorded with provider and lookup time.
- Four CTF answers submitted and score/attempt details recorded.
- Findings distinguish observed header values from analytical conclusions.

8. EXPECTED LEARNING OUTCOME

Participants should be able to conduct a basic phishing-email header investigation, extract the four requested indicators, explain how each was derived, and submit the results to the CTF. They should understand the limitations of email-header attribution and IP geolocation, and avoid unsupported claims about the identity or physical location of a sender.

9. CTF SCORING AND VALIDATION

Challenge item	Points
Recipient email domain	10
Sender / attacker domain	10
Source IP from Received headers	10
Country associated with the IP	10
Total possible score	**40**

The supplied HTML implements four questions worth 10 points each. Correct responses are locked in and contribute to the score. The page stores progress locally in the browser; participants should follow the organiser's instructions for retaining or submitting their final score.